How the Hive security skill works

A four-step cycle, with explicit user choice before fixes and evidence-based verification.

RECOMMENDED WORKFLOW

1. Inspect

Reviews all 345 pinned ASVS 5.0.0 requirements against repository evidence.

Updates the current matrix, needs-information list, not-applicable list, and follow-up queue.

2. Audit

Default scope: all 188 applicable L1+L2 requirements in the recorded snapshot.

Needs-information items stay in scope. L3 and exact justified N/A IDs are excluded.

3. Fix

Before editing, asks you to choose:

1. Selected findings only
2. All open findings in a report
3. Plan only (no code edits)

4. Verify

Checks pending changes using code, tests, and runtime/deployment evidence when available.

Result: verified/pass, still open/fail, or verification pending.

What each step leaves behind

Inspection records

Per-requirement status and evidence; separate lists for unknowns and justified exclusions.

Audit and fix records

Dated audit/fix reports. “No issue identified” only describes the review; it is not a test or pass.

Verification record

A separate dated report. Keep unresolved deployment checks pending and leave the requirement in the queue.

After meaningful fixes or scope changes

Run security-inspect again. It refreshes coverage and the queue from evidence; it does not automatically mark requirements passed.

Exact assessment scope and coverage

Numbers below are copied from the current inspection matrix; no rounded requirement counts.

Pinned ASVS 5.0.0 inventory

345 total requirements

L1: 70 | L2: 183 | L3: 92

L1 + L2 baseline: 253

253 / 345 = 73.3% of the pinned catalog. This describes catalog share, not completion.

Subtract justified N/A: 65

18 L1 + 47 L2. Excluded from scope and never counted as covered.

253 - 65 = 188 applicable L1+L2 requirements

This is the default full-audit denominator. Needs-information requirements remain included.

Recorded L1+L2 implementation statuses

Covered	Partially covered	Not covered	Needs information
47 requirements	40 requirements	33 requirements	68 requirements

Implementation coverage

47 / 188 = 25.0%
Hive target: 100% of applicable L1+L2.
Needs-information items remain in the denominator and do not count as covered.

Verification and conformance

0 / 188 = 0.0% verification passes.
L2 conformance requires a pass for every applicable L1/L2 requirement (100%).
Implementation coverage and verification are separate measures.

All-level context: 50/345 catalog evidence coverage = 14.5%; 50/260 applicability coverage = 19.2%. Across all levels: 50 covered, 50 partial, 60 not covered, 100 need information, 85 not applicable, 0 not assessed.

How to read the reports

Plain-language guide to the current snapshot and the limits of earlier audit results.

In simple terms

Inspect

“What evidence do we have?” Records implementation evidence and what remains unknown.

Audit

“What concrete weaknesses can we find?” Reviews each requirement in scope and documents what was checked.

Fix

“What should we try to change?” You choose selected findings, all open findings, or a plan with no edits.

Verify

“Did the change work?” Missing runtime/deployment evidence stays pending.

Current recorded state

Latest inspection: 2026-10-21, based on commit 1be166c. The follow-up verification report records 0/188 L1+L2 passes; current repository documentation commit is 432ca3a.

Latest audit correction: one unique finding was mapped to two requirements, while 186 of 188 applicable requirements were not individually assessed. That audit does not establish that all other requirements have no vulnerabilities.

HIVE-SEC-2026-002 maps to v5.0.0-V2.4.1 and v5.0.0-V15.2.2. The API test suite and typecheck passed; the prior local PostgreSQL-backed HTTP check also passed. The finding remains verification pending because production proxy behavior, replica count, memory limits, and edge-wide controls were unavailable.

Quick command examples

```
$hive-security security-inspect
```

```
$hive-security security-audit
```

```
$hive-security security-audit v5.0.0-V2.4.1
```

```
$hive-security security-fix
```

```
$hive-security security-verify
```

Use one repo-local skill and name the mode. They are modes, not separate slash commands. Source files: docs/security/README.md and .agents/skills/hive-security/SKILL.md.